Seguridad en los Sistemas de Información

Parcial 1 · Desarrollo integral del temario

Material de estudio organizado según el Temario unificado — SSI Parcial 1. Incluye desarrollo de los contenidos de Control Interno y Auditoría Informática; Código de Buenas Prácticas; capítulos 6, 7, 8 y 9 de Seguridad y Controles; y los controles señalados de ISO/IEC 27002:2022 (versión española UNE-EN ISO/IEC 27002:2023).

Criterio de elaboración. Se respeta la secuencia del temario y se parafrasean las fuentes con fines de estudio. Las explicaciones de los controles ISO son síntesis interpretativas y no reproducciones literales de la norma. Las referencias 2007 y 2022 se distinguen expresamente porque su numeración no es equivalente.

Fuentes utilizadas

Auditoría y Control Interno (capítulo 2, Control interno y auditoría informática).

Seguridad en los Sistemas de Información — Seguridad y Controles (capítulos 6, 7, 8 y 9), UTN FRRo.

Seguridad en los Sistemas de Información, capítulo 2: Código de buenas prácticas (edición 2007).

UNE-EN ISO/IEC 27002:2023, adopción española de ISO/IEC 27002:2022.

Índice de capítulos

1. Control interno y auditoría informática

2. Código de buenas prácticas — Marco para relacionar los capítulos

3. Capítulo 6 — Gestión de operaciones y comunicaciones

4. Capítulo 7 — Seguridad de acceso y del entorno

5. Capítulo 8 — Seguridad organizacional

6. Capítulo 9 — Gestión de la continuidad del negocio

1. CONTROL INTERNO Y AUDITORÍA INFORMÁTICA

1.1. Conceptos fundamentales

El control interno es el conjunto de políticas, procedimientos, responsabilidades y actividades que una organización integra en su gestión para ofrecer una seguridad razonable respecto del logro de sus objetivos. No consiste únicamente en detectar errores contables: comprende la protección de activos, la confiabilidad de la información, la eficacia de las operaciones y el cumplimiento de disposiciones aplicables. Su eficacia depende tanto del diseño de los mecanismos como de su operación cotidiana y del compromiso de quienes los ejecutan.

En el ámbito informático, ese enfoque se aplica al tratamiento de información, programas, infraestructura, comunicaciones y servicios tecnológicos. Un control informático es una medida concreta —técnica, organizativa o procedimental— que contiene o modifica un riesgo: por ejemplo, autenticar usuarios, separar funciones o realizar copias de seguridad. La auditoría informática, en cambio, es una actividad de examen sistemático que obtiene y evalúa evidencias para formar un juicio sobre la protección de activos, integridad de datos, confiabilidad, eficacia, eficiencia y adecuación de los controles. La secuencia conceptual es: identificar objetivos, reconocer riesgos que podrían impedirlos, elegir e implantar controles, verificar sus resultados y corregir desviaciones.

1.1.1. Definición de control interno.

El control interno se integra a los procesos administrativos y operativos y proporciona seguridad razonable, no certeza absoluta. Sus medidas se definen según los objetivos, los riesgos y los recursos de la entidad.

1.1.2. Definición de control interno informático.

El control interno informático aplica el control a las operaciones y servicios de sistemas, comprobando observancia de procedimientos, normas de la dirección y requisitos legales.

1.1.3. Definición de auditoría informática.

La auditoría informática es un examen de evidencias sobre sistemas informatizados, controles y resultados para emitir conclusiones fundadas y propuestas de mejora.

1.1.4. Definición de control informático.

Un control informático puede ser una política, una configuración técnica, una aprobación, un registro o una verificación. No todos los controles son herramientas automáticas.

1.1.5. Relación entre riesgos, objetivos y controles.

Los objetivos determinan qué debe alcanzarse; el riesgo expresa la posibilidad de no lograrlo; los controles se seleccionan para reducir o contener ese riesgo. El riesgo residual es el que permanece luego de aplicar medidas.

1.2. Diferencias entre control interno y auditoría informática [FUNDAMENTAL]

La distinción central es entre actuar sobre los riesgos y evaluar de forma objetiva cómo se actúa sobre ellos. El control interno informático opera de manera habitual, acompaña los procesos y ayuda a que

procedimientos y medidas sean cumplidos. La auditoría informática examina los sistemas y controles en momentos definidos o mediante planes de auditoría y comunica conclusiones basadas en evidencias. No debe confundirse la revisión independiente con la responsabilidad de implantar los controles: ésta corresponde a los propietarios de procesos, activos y sistemas, con el apoyo de las áreas de control.

En el texto de Auditoría y Control Interno, el control interno informático se presenta normalmente como órgano de apoyo a la dirección de informática, mientras que la auditoría tiene una función de revisión y comunicación de resultados hacia la dirección y otros destinatarios responsables de la gobernanza. Pueden existir auditorías internas y externas. Ambas funciones comparten el interés por proteger activos, asegurar la integridad de la información y alcanzar los objetivos institucionales. Se complementan porque la auditoría identifica debilidades y recomienda mejoras, mientras que los responsables operativos instrumentan y sostienen las medidas.

1.2.1. Finalidad y objetivos.

El control interno busca prevenir y tratar fallos durante la gestión; la auditoría busca obtener una valoración independiente y documentada acerca de cómo se gestiona y controla.

1.2.2. Alcance y responsabilidades.

El control interno alcanza las actividades que se ejecutan en la organización y se apoya en los responsables operativos; la auditoría define alcance y criterios de examen y debe preservar objetividad.

1.2.3. Actividades permanentes y evaluaciones periódicas.

La ejecución de controles es continua o recurrente en función del proceso; la auditoría efectúa evaluaciones planificadas o motivadas por riesgos y cambios relevantes.

1.2.4. Implantación y operación de controles frente a revisión independiente.

Quien diseña y opera un control debe responder por su funcionamiento. El auditor verifica si está bien diseñado y funciona, pero no debería convertirse en operador de aquello que audita.

1.2.5. Dependencia organizacional y destinatarios de los informes.

El área de control puede apoyar estrechamente a informática; los resultados de auditoría se informan a los niveles de dirección o gobierno correspondientes según la independencia requerida.

1.2.6. Puntos en común y complementariedad.

Ambas disciplinas tratan riesgos, activos, procesos, normas y evidencia. Los hallazgos de auditoría alimentan la mejora del sistema de control sin sustituir la responsabilidad de los gestores.

1.3. Control interno informático

El control interno informático comprueba diariamente que las actividades de los sistemas de información respeten las políticas, estándares, normas y requisitos legales pertinentes. Sus funciones incluyen verificar controles de cambios y versiones, supervisar operaciones de producción, desarrollo y pruebas, controlar redes y bases de datos, y revisar la correcta administración de recursos y perfiles

de usuarios. También asesora en la interpretación de normas y contribuye a difundir la cultura de seguridad.

La función no reemplaza las responsabilidades de quienes administran cada servicio o activo. Cada responsable debe instrumentar medidas adecuadas a los riesgos bajo su esfera, mientras control interno establece comprobaciones, seguimiento y asesoramiento. La prevención de errores e irregularidades requiere reglas claras, autorizaciones, trazabilidad y mecanismos de detección; el seguimiento exige resultados verificables e indicadores de cumplimiento para identificar fallas y realizar ajustes.

1.3.1. Funciones y objetivos.

Sus funciones incluyen supervisar la adecuación de medidas establecidas, asesorar, revisar calidad del servicio y coordinar verificaciones de controles tecnológicos.

1.3.2. Cumplimiento de políticas, normas y procedimientos.

Se verifica que las tareas se ejecuten de acuerdo con procedimientos aprobados, estándares técnicos, políticas institucionales y normas vigentes; también deben comunicarse los cambios.

1.3.3. Prevención de errores, irregularidades y usos indebidos.

Las medidas preventivas, el seguimiento y la detección buscan reducir errores accidentales, fraude, abuso de privilegios y uso de sistemas fuera de autorizaciones.

1.3.4. Responsabilidades sobre los sistemas y recursos informáticos.

Propietarios de datos, administradores, operadores, desarrolladores y usuarios tienen deberes diferentes. La función de control facilita su claridad, pero no absorbe esas responsabilidades.

1.3.5. Seguimiento del desempeño y de los mecanismos de control.

El seguimiento recaba evidencias sobre ejecución, fallas y eficacia de controles. Cuando una medida resulta insuficiente, se revisan causa, responsable, plazo y necesidad de corrección.

1.4. Auditoría informática

La auditoría informática reúne, examina y valora evidencias para determinar si los sistemas de información salvaguardan activos, preservan la integridad de los datos, contribuyen eficazmente a los objetivos de la organización y utilizan los recursos con eficiencia. Su trabajo puede abordar aplicaciones nuevas o existentes, cambios importantes, controles generales, controles de aplicación, infraestructura, continuidad y cumplimiento normativo.

La revisión debe distinguir entre diseño y funcionamiento: un control puede estar correctamente documentado y, sin embargo, no ejecutarse; también puede ejecutarse, pero no mitigar el riesgo previsto. La evidencia puede incluir registros, configuraciones, entrevistas, inspecciones, documentación de autorizaciones, observación de procedimientos y resultados de pruebas. El informe registra alcance, criterios, hallazgos, consecuencias y recomendaciones, señalando responsables y acciones correctivas. La auditoría interna pertenece al sistema de gobierno de la entidad y requiere independencia respecto de lo auditado; la externa es realizada por profesionales ajenos a la organización, con alcance acordado.

1.4.1. Funciones y objetivos.

La auditoría revisa seguridad, exactitud e integridad de datos, eficiencia de recursos, eficacia de procesos y ajuste a requisitos establecidos.

1.4.2. Obtención y evaluación de evidencias.

La evidencia debe ser pertinente y suficiente para sustentar hallazgos; es habitual combinar documentación, entrevistas, observación y pruebas de configuraciones o transacciones.

1.4.3. Revisión de la eficacia, eficiencia, seguridad y fiabilidad.

Eficacia es logro de objetivos, eficiencia es utilización adecuada de recursos, seguridad es protección ante riesgos y fiabilidad es comportamiento e información dignos de confianza.

1.4.4. Evaluación del diseño y funcionamiento de los controles.

El diseño de un control se evalúa preguntando si puede prevenir o detectar el riesgo; su funcionamiento se verifica observando si se ejecutó correctamente durante el período relevante.

1.4.5. Comunicación de resultados y recomendaciones.

Los informes deben expresar criterios, hechos comprobados, riesgo o consecuencia, conclusión y recomendación. Los responsables del proceso determinan y ejecutan acciones correctivas.

1.4.6. Auditoría interna y auditoría externa.

La auditoría interna forma parte de la organización y exige independencia funcional suficiente; la externa procede de profesionales ajenos y aporta una perspectiva independiente según su encargo.

1.5. Sistema de controles informáticos

Un sistema de controles informáticos combina objetivos de control con métodos concretos de aplicación. Un objetivo indica qué condición de seguridad o fiabilidad se busca; el método expresa cómo se obtendrá y comprobará. Los controles preventivos reducen la probabilidad de ocurrencia de un evento (autorizaciones, segregación de funciones, validación de entradas); los detectivos identifican situaciones anómalas cuando se producen o después (alarmas, conciliaciones, revisión de registros); los correctivos limitan daños y restablecen condiciones aceptables (restauraciones, revocación de credenciales, reparación de configuraciones).

También conviene distinguir controles generales, aplicables al entorno tecnológico transversal —operación, desarrollo, accesos, infraestructura, cambios—, de controles de aplicación, vinculados al funcionamiento de un sistema particular —validaciones, integridad de transacciones, autorizaciones de operaciones y salidas—. Sus áreas habituales son organización, desarrollo, explotación o producción y comunicaciones. El control de cambios evita modificaciones no aprobadas o sin pruebas; la separación de funciones evita concentrar solicitud, aprobación, ejecución y verificación en una misma persona.

1.5.1. Objetivos de control y métodos de control.

Un objetivo de control expresa el resultado esperado, como impedir modificaciones no autorizadas; el método describe su implementación mediante permisos, aprobaciones y comprobación de registros.

1.5.2. Controles preventivos.

Los controles preventivos actúan antes del incidente: autenticación, segregación de funciones, formación, restricciones de acceso y revisión previa de cambios.

1.5.3. Controles detectivos.

Los detectivos revelan hechos anómalos: alertas, monitoreo, inspección de registros, conciliaciones y revisiones de accesos.

1.5.4. Controles correctivos.

Los correctivos restablecen condiciones adecuadas tras una falla: restauración de backups, corrección de configuraciones, contención de malware y retiro de privilegios indebidos.

1.5.5. Controles generales y controles de aplicación.

Los controles generales establecen condiciones de confiabilidad del entorno TIC; los de aplicación resguardan transacciones, entradas, procesamiento y salidas de un sistema específico.

1.5.6. Áreas de aplicación: organización, desarrollo, explotación y comunicaciones.

En organización importan reglas y responsabilidades; en desarrollo, autorización y prueba; en explotación, operación estable y respaldos; en comunicaciones, protección del tránsito y administración de redes.

1.5.7. Control de cambios y separación de funciones.

Los cambios deben solicitarse, autorizarse, probarse, implementarse y registrarse. Separar tareas reduce la posibilidad de que una misma persona introduzca y oculte modificaciones irregulares.

1.6. Relación con las buenas prácticas y la norma

La ISO/IEC 27002:2022 ofrece una referencia de controles orientados al tratamiento de riesgos. El control 5.1 se ocupa de la definición, aprobación, publicación y revisión de políticas de seguridad; el 5.36 propone comprobar el cumplimiento de políticas, reglas y normas de seguridad. El 5.35 establece revisiones independientes de la gestión y práctica de la seguridad, en intervalos planificados o ante cambios importantes. El 8.34 exige planificar y acordar las pruebas de auditoría y proteger durante ellas los sistemas de producción, evitando impactos operativos, accesos indebidos o alteración de datos. Las referencias de estos controles no deben confundirse con la numeración de la edición 2007.

1.6.1. Política y cumplimiento de controles (ISO 27002:2022, 5.1 y 5.36).

5.1 establece políticas aprobadas, comunicadas y revisadas; 5.36 exige comprobar que personas, procesos y sistemas cumplan políticas y normas de seguridad definidas.

1.6.2. Revisión independiente de la seguridad (ISO 27002:2022, 5.35).

5.35 promueve una revisión independiente de la gestión de seguridad a intervalos planificados o cuando existan cambios significativos.

1.6.3. Protección de sistemas durante pruebas de auditoría (ISO 27002:2022, 8.34).

8.34 exige que las pruebas de auditoría sobre sistemas operativos se acuerden y controlen para evitar daño, interrupción y exposición de información.

2. CÓDIGO DE BUENAS PRÁCTICAS — MARCO PARA RELACIONAR LOS CAPÍTULOS

2.1. Norma ISO/IEC 27002 como código de buenas prácticas

ISO/IEC 27002 es un código de buenas prácticas y catálogo orientativo de controles de seguridad de la información. Complementa la gestión de riesgos y puede servir de referencia para seleccionar controles dentro de un sistema de gestión de seguridad de la información (SGSI) basado en ISO/IEC 27001, o para formular directrices propias de una organización. La norma no establece que cada control deba aplicarse indiscriminadamente: su elección depende de los riesgos identificados, los requisitos de negocio y las obligaciones legales y contractuales.

El capítulo 2 de la cátedra describe la edición 2007 organizada en secciones 5 a 15, con once dominios de buenas prácticas y categorías de objetivos de control; expone los controles junto con orientaciones para su implementación e información adicional. La versión ISO/IEC 27002:2022 reorganiza su catálogo en cuatro tipos: controles organizativos (capítulo 5), de personas (6), físicos (7) y tecnológicos (8), y añade atributos para clasificarlos. La correspondencia entre versiones es temática, no una equivalencia directa por el número: algunos controles se fusionaron, otros fueron añadidos o reorganizados.

2.1.1. Finalidad y alcance.

La finalidad de ISO/IEC 27002 es ofrecer controles de referencia y orientaciones de aplicación para organizaciones de distinto tipo y tamaño. Su alcance es la protección de información y activos asociados frente a riesgos relevantes; no sustituye la evaluación del contexto propio.

2.1.2. Relación con la gestión de la seguridad de la información.

La gestión de seguridad de la información define objetivos, evalúa riesgos, asigna responsabilidades, selecciona medidas y verifica su eficacia. ISO/IEC 27002 constituye una guía de controles que puede utilizarse al definir el tratamiento de riesgos de un SGSI, habitualmente articulado con ISO/IEC 27001.

2.1.3. Estructura de la versión 2007 utilizada en el capítulo 2.

La edición 2007 presentada en el capítulo 2 separa una sección introductoria de once secciones de buenas prácticas, numeradas del 5 al 15. Sus temas abarcan política, organización, activos, personas, instalaciones, operaciones, acceso, desarrollo, incidentes, continuidad y cumplimiento.

2.1.4. Objetivos de control, controles y directrices de implementación.

Un objetivo de control expresa una condición de seguridad esperada; cada control describe una medida y las directrices de implementación explican cómo llevarla a la práctica. La información adicional aporta contexto y consideraciones para su adaptación.

2.1.5. Estructura de controles de la versión 2022: organizativos, de personas, físicos y tecnológicos.

La versión 2022 presenta controles organizativos en el capítulo 5, de personas en el 6, físicos en el 7 y tecnológicos en el 8. Esta organización permite identificar el tipo de medidas requeridas y combinarlas para obtener protección en profundidad.

2.1.6. Correspondencia conceptual entre las ediciones 2007 y 2022.

Las materias de la edición 2007 pueden vincularse con las de 2022 por su finalidad, pero la numeración cambió, algunos controles se fusionaron y otros se incorporaron. Por ello, el número 7.1 en una edición no debe interpretarse como el mismo control que el 7.1 en la otra.

2.2. Análisis, evaluación y tratamiento de riesgos (sección 4 de 2007).

La sección 4 de la edición 2007 presenta el análisis, evaluación y tratamiento de riesgos como base para decidir qué proteger y con qué intensidad. El análisis identifica activos, amenazas y vulnerabilidades; la evaluación estima probabilidad y consecuencias; el tratamiento selecciona medidas para reducir, modificar, evitar o aceptar los riesgos conforme a los criterios de la organización. La edición 2022 también remite a la evaluación de riesgos para determinar controles adecuados, evitando una implantación mecánica del catálogo.

2.3. Política de seguridad de la información (sección 5 de 2007).

La sección 5 de 2007 trata la política de seguridad como declaración de orientación y respaldo de la dirección. Debe alinearse con los objetivos del negocio, establecer el marco general de conducta y ser comunicada y revisada. En 2022 estos asuntos se vinculan especialmente con 5.1 (políticas para la seguridad de la información), con 5.36 (cumplimiento) y con los roles y responsabilidades definidos en 5.2.

2.4. Organización de la seguridad de la información (sección 6 de 2007) → Capítulo 8.

La sección 6 de 2007 se refiere a cómo organizar la seguridad dentro de la institución y en las relaciones con partes externas. Incluye asignación de responsabilidades, coordinación, autorización y condiciones de acceso de terceros. Se desarrolla principalmente en el capítulo 8 de este material; en la edición 2022 aparecen controles organizativos relativos a roles, segregación, proveedores y gestión de servicios.

2.5. Gestión de activos (sección 7 de 2007) → Capítulo 8.

La sección 7 de 2007 aborda la responsabilidad sobre activos y la clasificación de la información: inventariar, asignar propietarios y adoptar protecciones conforme al valor y sensibilidad. En la versión 2022 se relaciona con inventarios (5.9), uso aceptable (5.10), devolución (5.11), clasificación (5.12) y etiquetado (5.13). El desarrollo principal se encuentra en el capítulo 8.

2.6. Seguridad de recursos humanos (sección 8 de 2007) → Capítulos 7 y 8.

La sección 8 de 2007 trata la seguridad de los recursos humanos antes, durante y al finalizar la relación con la organización. Comprende selección, condiciones contractuales, concientización,

responsabilidades, sanciones y retiro de accesos. Su contenido se conecta con los capítulos 7 y 8 y con los controles de personas 6.1 a 6.8 de la edición 2022.

2.7. Seguridad física y del entorno (sección 9 de 2007) → Capítulo 7.

La sección 9 de 2007 reúne seguridad física y ambiental: áreas seguras, perímetros, entrada, emplazamiento y cuidado de equipos, suministros y condiciones del entorno. El capítulo 7 explica esos riesgos y el apartado 3.9 del presente documento desarrolla los catorce controles físicos 7.1–7.14 de la edición 2022, conforme a la ubicación solicitada por la cátedra.

2.8. Gestión de operaciones y comunicaciones (sección 10 de 2007) → Capítulo 6.

La sección 10 de 2007 cubre las operaciones y comunicaciones: procedimientos, proveedores, capacidad, malware, copias de seguridad, redes, soportes, intercambios, comercio electrónico y monitoreo. En este documento la explicación detallada corresponde al capítulo 6. La edición 2022 distribuye estas materias entre controles organizativos y tecnológicos, como 5.14, 5.37, 8.7, 8.13, 8.15, 8.20 y 8.22.

2.9. Control de acceso (sección 11 de 2007) → Capítulo 7.

La sección 11 de 2007 corresponde al control de acceso: requerimientos, administración de usuarios, autenticación, privilegios y supervisión del uso de recursos. Se desarrolla en el capítulo 7. En la edición 2022 destacan 5.15 a 5.18, junto con controles tecnológicos de autenticación, privilegios y restricciones de acceso.

2.10. Adquisición, desarrollo y mantenimiento de sistemas (sección 12 de 2007) → Capítulos 6 y 8.

La sección 12 de 2007 se ocupa de incorporar seguridad en la adquisición, desarrollo y mantenimiento de sistemas. Incluye requisitos de seguridad, controles en aplicaciones, protección de archivos y procesos, desarrollo seguro y gestión de vulnerabilidades. Sus vínculos principales son la gestión de cambios y entornos del capítulo 6, la organización y responsabilidad de proyectos del capítulo 8 y los controles tecnológicos de desarrollo seguro de 2022.

2.11. Gestión de incidentes de seguridad (sección 13 de 2007) → Capítulos 6, 8 y 9.

La sección 13 de 2007 propone comunicar eventos, identificar incidentes, asignar responsables, responder y aprender de lo ocurrido. El monitoreo del capítulo 6 ayuda a detectar anomalías; el capítulo 8 asigna funciones y establece relaciones con terceros; el capítulo 9 explica la notificación, el escalamiento y la respuesta ante eventos adversos. En 2022 estos conceptos se relacionan con 5.24–5.28 y 6.8.

2.12. Gestión de la continuidad del negocio (sección 14 de 2007) → Capítulo 9.

La sección 14 de 2007 busca evitar que los incidentes graves se conviertan en interrupciones prolongadas del negocio. La continuidad requiere identificar procesos críticos, establecer estrategias

de respuesta y recuperación y comprobar los planes. Su desarrollo corresponde al capítulo 9, complementado por los controles 5.29 y 5.30 de 2022.

2.13. Cumplimiento (sección 15 de 2007) → Control interno, auditoría y capítulos 6 a 9.

La sección 15 de 2007 presenta la observancia de requisitos legales, reglamentarios, contractuales y de las políticas propias, así como la revisión de su cumplimiento. Se vincula directamente con control interno y auditoría y atraviesa los capítulos operativos. En ISO/IEC 27002:2022 son particularmente pertinentes 5.31, 5.35 y 5.36.

3. CAPÍTULO 6 — GESTIÓN DE OPERACIONES Y COMUNICACIONES

3.1. Objetivos de la gestión de operaciones y comunicaciones.

La gestión de operaciones y comunicaciones procura que los servicios informáticos funcionen de forma estable y segura según los requisitos de la organización. Comprende operación de sistemas, servicios subcontratados, protección frente al malware, copias de seguridad, manejo de medios, seguridad de redes, transferencia de información y vigilancia continua. Su función es preservar la confidencialidad, integridad y disponibilidad de la información durante las actividades cotidianas, minimizando errores, interrupciones y modificaciones no autorizadas.

3.2. Procedimientos y responsabilidades operacionales

Los procedimientos de operación deben documentarse en forma clara, mantenerse actualizados y ser modificables mediante autorizaciones. Deben explicar tareas habituales, tratamiento de errores, mantenimiento, recuperación, respaldos, contactos de soporte y actuaciones ante condiciones adversas. Las responsabilidades deben quedar asignadas y las funciones incompatibles separadas: la misma persona no debería poder aprobar, ejecutar y validar sin supervisión una operación crítica.

El cambio operativo requiere solicitud, evaluación de riesgo e impacto, autorización, pruebas, comunicación, registro y posibilidad de reversión. Deben separarse los entornos de desarrollo, pruebas y producción para impedir que código o datos no autorizados afecten el servicio. La planificación de capacidad anticipa necesidades de procesamiento, almacenamiento y comunicaciones; la aceptación de sistemas fija criterios verificables de rendimiento, seguridad, recuperación y disponibilidad antes de su puesta en marcha. Los servicios tercerizados necesitan compromisos de calidad y seguridad y seguimiento de su ejecución.

3.2.1. Documentación de procedimientos operativos.

Debe existir documentación accesible de arranque y cierre, operaciones de rutina, errores, mantenimiento, copias y recuperación. El procedimiento se revisa cuando cambian herramientas o responsabilidades.

3.2.2. Responsabilidades de operación y soporte.

Operadores y personal de soporte deben conocer sus tareas, las autorizaciones necesarias, los canales de escalamiento y los límites de su intervención. Una falla necesita responsables designados.

3.2.3. Segregación de funciones y responsabilidades.

La segregación impide que una persona concentre autorización, ejecución y verificación de actividades incompatibles. Si el tamaño organizacional limita la separación, deben considerarse supervisiones compensatorias.

3.2.4. Gestión de cambios operativos.

Los cambios operacionales deben registrarse con motivos, impacto, aprobación, pruebas y reversión. Los cambios urgentes requieren controles acordes a su necesidad y revisión posterior.

3.2.5. Separación de entornos de desarrollo, prueba y producción.

Desarrollo, pruebas y producción requieren cuentas, datos y permisos diferenciados; los pases a producción deben ser autorizados y verificables para limitar modificaciones accidentales o maliciosas.

3.2.6. Gestión de capacidad y planificación de recursos.

La planificación de capacidad anticipa demanda, uso de CPU, memoria, almacenamiento, enlaces y crecimiento. Se procura garantizar rendimiento sin esperar a que ocurra una saturación.

3.2.7. Aceptación, homologación y pruebas de sistemas.

Antes de aceptar un sistema se definen criterios de rendimiento, capacidad, recuperación, seguridad y funcionamiento. Homologar supone comprobar y documentar que esos criterios se cumplan.

3.2.8. Gestión y supervisión de servicios tercerizados.

La tercerización no elimina la responsabilidad organizacional. Deben existir requisitos contractuales, niveles de servicio, supervisión periódica y gestión de cambios del proveedor.

3.3. Protección contra software malicioso

El software malicioso incluye virus, gusanos, troyanos, bombas lógicas y otras formas de código que alteran sistemas, roban información o dificultan su disponibilidad. La protección exige combinar concientización de usuarios, restricciones de instalación, control de acceso, gestión de cambios, software autorizado y herramientas de detección correctamente actualizadas. Es necesario examinar archivos adjuntos, descargas, soportes extraíbles y contenido recibido desde redes o terceros, tanto en servidores como en puestos de trabajo.

Las licencias y autorizaciones de uso deben respetarse; instalar programas de origen desconocido introduce riesgos técnicos y de cumplimiento. No alcanza con instalar un antivirus una sola vez: deben actualizarse herramientas y firmas, revisar alertas, analizar configuraciones y contar con procedimientos de aislamiento, eliminación de amenazas y recuperación después de un incidente.

3.3.1. Tipos de software malicioso.

Los virus se asocian con archivos o programas; los gusanos se propagan entre sistemas; los troyanos aparentan legitimidad; una bomba lógica activa acciones al producirse ciertas condiciones. Todos requieren evaluación según su efecto.

3.3.2. Prevención, detección y recuperación.

La defensa combina prevención mediante permisos y formación, detección con herramientas y controles de actividad, y recuperación mediante aislamiento, limpieza, restauración y revisión de causas.

3.3.3. Uso autorizado y licenciamiento del software.

La organización debe permitir la instalación de software legítimo y autorizado, revisar condiciones de licencia y evitar fuentes que dificulten conocer integridad y procedencia.

3.3.4. Análisis y actualización de herramientas de protección.

Las herramientas deben mantenerse actualizadas y sus alertas atenderse. Los archivos recibidos, las descargas y los soportes de origen incierto deben someterse a verificaciones apropiadas.

3.4. Copias de seguridad

Los respaldos permiten recuperar información y software después de pérdida, corrupción, borrado accidental o desastre. Protegen particularmente integridad y disponibilidad, pero sólo son útiles si existen copias recientes, protegidas y restaurables dentro del tiempo admisible. Una política de backup define qué activos se respaldan, quién lo hace, qué modalidad se utiliza, con qué frecuencia, dónde se conservan los duplicados, cuánto tiempo se retienen y cómo se verifican.

Una copia completa reproduce todos los datos seleccionados; una incremental almacena los cambios desde la copia anterior que corresponda. La frecuencia depende de la criticidad y de cuánta información puede perder el negocio; el almacenamiento debe evitar que el mismo suceso destruya original y respaldo. Deben aplicarse protecciones físicas y lógicas, controles de acceso y pruebas regulares de los medios y de restauración. La continuidad del negocio requiere comprobar que la recuperación real cumple los objetivos propuestos, no solamente verificar que el proceso de copia terminó sin errores.

3.4.1. Objetivos y requisitos de recuperación.

Un backup se diseña para recuperar datos con integridad y disponibilidad dentro de límites aceptables. El tiempo de recuperación y la pérdida tolerable de datos influyen en la solución.

3.4.2. Política de copias de seguridad.

La política identifica alcance, responsables, modalidades, calendario, retención, protección, ubicación y pruebas. Debe concordar con el valor de cada activo y las exigencias de continuidad.

3.4.3. Copias completas e incrementales.

Una copia completa guarda todo el conjunto seleccionado; la incremental guarda cambios respecto de una copia previa, permitiendo ahorrar recursos, aunque la restauración puede depender de varias copias.

3.4.4. Frecuencia y criticidad de la información.

La frecuencia crece cuando los datos cambian rápidamente o su pérdida es costosa. No existe un intervalo único válido para todas las clases de información.

3.4.5. Almacenamiento, protección y ubicación remota.

Las copias deben resguardarse de accesos no autorizados y de desastres que afecten a la ubicación principal. La distancia, el soporte y las protecciones se definen según riesgos.

3.4.6. Verificación y pruebas de restauración.

La creación correcta de un archivo no garantiza restauración. Es imprescindible probar medios, procedimientos, integridad de datos y tiempos de recuperación periódicamente.

3.5. Tratamiento de medios y documentos

Los soportes y documentos pueden sufrir pérdida, robo, interceptación, alteración o destrucción durante su uso, transporte o descarte. El tratamiento debe partir de la clasificación de la información para determinar quién puede utilizar cada soporte, cómo se protege su contenido y cuánto tiempo debe conservarse. Los medios removibles exigen autorización, inventario cuando corresponda, almacenamiento seguro y restricciones de copia.

El transporte seguro requiere identificar responsables, destinatarios, condiciones de embalaje, mecanismos de seguimiento y entrega, y protección de la información durante el traslado. Cuando un medio o documento deja de ser necesario, debe eliminarse de forma que la información no pueda recuperarse de manera no autorizada: trituración para papel y técnicas de borrado seguro o destrucción física apropiadas para soportes electrónicos, con evidencia cuando su criticidad lo requiera.

3.5.1. Clasificación y protección de la información almacenada.

La clasificación determina cuánto debe restringirse y protegerse la información contenida en soportes y documentos, tanto en tránsito como en almacenamiento.

3.5.2. Gestión de soportes removibles.

Los medios removibles necesitan reglas de autorización, uso, custodia y eliminación, porque pueden extraviarse o facilitar transferencias de información no controladas.

3.5.3. Transporte seguro de medios.

La entrega a transportistas, el embalaje y la recepción deben estar definidos; para información sensible se consideran mecanismos adicionales de protección y trazabilidad.

3.5.4. Eliminación segura de soportes y documentos.

Los documentos y soportes no deben descartarse como residuos comunes cuando contienen información protegida. Deben utilizarse medios de destrucción o borrado pertinentes.

3.6. Gestión de la seguridad de las redes

La gestión de redes protege tanto la infraestructura de comunicación como los datos que circulan por ella. Deben identificarse los administradores responsables, separar tareas de operación y seguridad cuando corresponda y documentar procedimientos para redes internas, enlaces externos, equipos y acceso remoto. Los servicios prestados por terceros requieren requisitos explícitos de seguridad y niveles de servicio acordados.

Las medidas pueden incluir filtrado de tráfico, protección de dispositivos de red, cifrado cuando corresponda, autenticación para acceso remoto, configuración y actualización segura, monitoreo y separación de redes o zonas con diferente sensibilidad. La segmentación limita la propagación de incidentes y los movimientos no autorizados entre sistemas. En redes inalámbricas se deben controlar los dispositivos y usuarios autorizados, la configuración de seguridad y la exposición del acceso.

3.6.1. Responsabilidades de administración de redes.

La administración de redes requiere asignación explícita de roles, documentación de configuraciones, control de cambios y separación de responsabilidades cuando resulte factible.

3.6.2. Protección de infraestructura y tráfico.

La infraestructura y la información en tránsito se protegen con medidas como configuración segura, controles de tráfico, monitoreo, autenticación y cifrado según el riesgo.

3.6.3. Servicios de red y niveles de servicio.

Los servicios de red deben tener requisitos de seguridad y niveles de servicio identificados, incluso si están a cargo de terceros, para poder verificar su desempeño.

3.6.4. Acceso remoto y comunicaciones inalámbricas.

El acceso remoto necesita autenticación y autorizaciones adecuadas; las redes inalámbricas exigen administración de equipos, permisos y configuración segura.

3.6.5. Segmentación y controles de red.

Separar redes en zonas con diferente sensibilidad reduce exposición y propagación de incidentes. Los controles de filtrado delimitan flujos permitidos y accesos de administración.

3.7. Transferencia de información y software

La transferencia de información y software incluye correo electrónico, archivos, servicios web, comunicaciones de voz o video, comercio electrónico y entrega de programas por proveedores. Toda modalidad de transferencia debe respetar la clasificación de la información, los requisitos legales y las políticas formales de intercambio. Cuando intervienen organizaciones diferentes, conviene establecer acuerdos con obligaciones de protección, destinatarios autorizados, medios permitidos, conservación, confirmación de entrega y respuesta frente a incidentes.

Se deben definir reglas claras para correo y servicios web, restringir divulgaciones o reenvíos no autorizados, verificar archivos recibidos y usar canales de comunicación apropiados al nivel de sensibilidad. La seguridad de la transferencia no termina al enviar: también incluye la correcta recepción, el uso acordado y las responsabilidades de todas las partes.

3.7.1. Políticas y acuerdos de intercambio.

Las políticas y acuerdos identifican información intercambiada, propósito, destinatarios, responsabilidades, medios autorizados y reacción frente a incidentes.

3.7.2. Comunicaciones internas y con terceros.

El intercambio interno debe respetar clasificación y necesidad de conocimiento; el intercambio con terceros exige reglas y obligaciones definidas entre participantes.

3.7.3. Correo electrónico, servicios web y transferencia de archivos.

Correo, servicios web y transferencias de archivos pueden facilitar divulgación indebida o malware. Las reglas deben contemplar destinatarios, adjuntos, autenticidad y canales seguros.

3.7.4. Seguridad y responsabilidades durante la transferencia.

La seguridad continúa durante envío, recepción, conservación y utilización de la información, con responsabilidades explícitas frente a errores o incidentes.

3.8. Monitoreo de operaciones y comunicaciones

El monitoreo de operaciones y comunicaciones debe ser regular, proporcional a los riesgos y apoyado por la dirección. Los registros de operación permiten reconstruir actividades de administradores y operadores, inicios y detenciones de sistemas, acciones de mantenimiento y cambios relevantes. Los registros de fallas documentan anomalías y medidas adoptadas. Los logs de auditoría registran accesos, actividades de usuarios, cambios de configuración e incidentes de interés para detectar abuso y establecer responsabilidades.

Los registros deben protegerse contra lectura, modificación o borrado no autorizados, conservarse durante un período adecuado y revisarse sistemáticamente. Su integridad y la sincronización de relojes son necesarias para reconstruir cronologías. La recolección y revisión deben respetar legislación y reglas de privacidad aplicables. Las alertas carecen de utilidad si no existe un procedimiento para analizarlas, determinar su gravedad y desencadenar medidas correctivas.

3.8.1. Registro de operaciones.

Los registros operacionales documentan acciones de operadores, inicios y cierres, mantenimiento y operaciones relevantes para reconstruir el funcionamiento de servicios.

3.8.2. Registro y tratamiento de fallas.

Los registros de fallas describen anomalías, contexto, responsable de atención y acciones correctivas. Su análisis permite detectar fallas recurrentes.

3.8.3. Registros de auditoría y actividad de usuarios.

Los logs de auditoría recogen accesos, acciones de usuarios, intentos fallidos y cambios de configuración; deben permitir revisión y trazabilidad.

3.8.4. Protección, revisión y conservación de logs.

Los registros necesitan integridad, permisos de consulta y conservación definidos, además de relojes sincronizados que permitan relacionar eventos entre equipos.

3.8.5. Detección y seguimiento de actividades no autorizadas.

El seguimiento regular de alertas e indicios permite identificar actividades no autorizadas y derivarlas a los responsables de respuesta de acuerdo con su criticidad.

3.9. Complemento obligatorio: controles físicos ISO 27002:2022, 7.1 a 7.14

Los controles 7.1 a 7.14 de ISO/IEC 27002:2022 constituyen el conjunto de controles físicos. Aunque se relacionan naturalmente con la seguridad del entorno del capítulo 7, este temario los ubica como complemento obligatorio del capítulo 6, según la indicación del profesor. Buscan impedir accesos físicos no autorizados, evitar pérdidas y daños en activos de información y mantener condiciones físicas apropiadas para la operación. Su implementación depende de la clasificación de las áreas, los riesgos del sitio y las necesidades reales de la organización.

3.9.1. 7.1 Perímetro de seguridad física.

Se delimitan áreas físicas en función de su criticidad, con barreras y controles coherentes con los activos protegidos. El perímetro debe identificar claramente la frontera entre zonas públicas, controladas y especialmente protegidas y evitar accesos no autorizados.

3.9.2. 7.2 Controles físicos de entrada.

Las entradas a edificios y áreas seguras deben contar con mecanismos que permitan únicamente a personas autorizadas ingresar. Se deben gestionar credenciales, accesos temporales, visitantes, registros de entradas y salidas y revisiones de autorizaciones.

3.9.3. 7.3 Seguridad de oficinas, despachos y recursos.

Oficinas, despachos, salas y otros espacios que albergan información deben ubicarse y protegerse según sus riesgos. Deben controlarse los accesos, evitar la exposición de información sensible y considerar el diseño físico de puertas, ventanas y dependencias.

3.9.4. 7.4 Monitorización de la seguridad física.

La seguridad física debe monitorearse para descubrir intrusiones y situaciones anormales oportunamente. La selección de vigilancia, cámaras, alarmas y otros mecanismos requiere proporcionalidad, procedimientos de revisión y respeto de las obligaciones legales y de privacidad.

3.9.5. 7.5 Protección contra amenazas externas y ambientales.

Las instalaciones deben protegerse de incendios, inundaciones, condiciones meteorológicas, fenómenos naturales y otras amenazas externas o ambientales. Corresponde evaluar el entorno físico, aplicar mitigaciones apropiadas y contar con procedimientos de emergencia.

3.9.6. 7.6 Trabajo en áreas seguras.

Las tareas en áreas seguras requieren reglas específicas de autorización y conducta. Conviene controlar el trabajo de personal externo, los dispositivos de grabación o comunicación cuando existan riesgos, la permanencia de visitantes y las labores fuera del horario normal.

3.9.7. 7.7 Puesto de trabajo despejado y pantalla limpia.

La política de puesto despejado y pantalla limpia reduce la exposición de información en papel, dispositivos y terminales desatendidos. Deben resguardarse documentos y soportes y bloquearse sesiones cuando la persona abandona su lugar de trabajo.

3.9.8. 7.8 Emplazamiento y protección de equipos.

Los equipos se ubican de modo que disminuyan el riesgo de accesos indebidos, daños, accidentes e interferencias. Se considera temperatura, ventilación, alimentación eléctrica, acceso para mantenimiento, derrames y exposición física.

3.9.9. 7.9 Seguridad de equipos fuera de las instalaciones.

Los equipos y la información utilizados fuera de instalaciones propias —incluidos portátiles y dispositivos móviles— requieren medidas basadas en riesgos de robo, daño, uso compartido y redes no confiables. Deben existir reglas para transporte, custodia y protección de datos.

3.9.10. 7.10 Soportes de almacenamiento.

Los soportes de almacenamiento deben administrarse durante todo su ciclo de vida, desde adquisición y uso hasta transporte, reutilización o descarte. Se consideran clasificación, autorización, inventario cuando aplique, almacenamiento seguro y eliminación de información.

3.9.11. 7.11 Instalaciones de suministro.

Los recursos de tratamiento de información dependen de electricidad y otros suministros como agua o climatización. Se evalúan fallas y se establecen medidas de protección, capacidad, seguimiento y alternativas de suministro según las necesidades de disponibilidad.

3.9.12. 7.12 Seguridad del cableado.

Los cables de energía y telecomunicaciones deben protegerse contra intercepción, interferencia, daños accidentales y manipulación. Las canalizaciones, la segregación física y el control de accesos a armarios y recorridos relevantes reducen la exposición.

3.9.13. 7.13 Mantenimiento de equipos.

El mantenimiento preventivo y correctivo de equipos se planifica para conservar su seguridad y funcionamiento. Deben establecerse responsables, registros, autorizaciones, medidas sobre datos y controles al permitir intervención de personal técnico externo.

3.9.14. 7.14 Eliminación o reutilización segura de equipos.

Antes de eliminar, devolver o reutilizar equipos se debe comprobar que la información sensible y el software sujeto a restricciones hayan sido retirados o borrados apropiadamente. Cuando el borrado no ofrece garantías suficientes, se considera destrucción del soporte y se documenta la operación.

4. CAPÍTULO 7 — SEGURIDAD DE ACCESO Y DEL ENTORNO

4.1. Política de control de acceso

La política de control de acceso debe definir formalmente cómo se autorizan y restringen los accesos físicos y lógicos según las necesidades del negocio y el riesgo de la información. Para formularla se consideran los recursos y aplicaciones utilizados, la sensibilidad y clasificación de datos, obligaciones legales y contractuales, los responsables que aprueban solicitudes y los criterios de

revisión y revocación de derechos. También determina cómo se tratarán excepciones y accesos temporales.

El acceso no se concede por mera disponibilidad técnica, sino por una necesidad legítima de trabajo. Es importante integrar la entrada a áreas físicas con los permisos en aplicaciones y sistemas: una persona sin autorización para manipular un servidor tampoco debería acceder libremente al recinto donde está instalado. Las autorizaciones deben reevaluarse ante cambios de puesto, desvinculaciones y variaciones en los activos protegidos.

4.1.1. Objetivos y requisitos del negocio.

El negocio determina quién necesita acceder, con qué finalidad, a qué recursos y durante cuánto tiempo. La política debe evitar permisos genéricos sin justificación.

4.1.2. Clasificación y sensibilidad de la información.

La clasificación de la información y su sensibilidad condicionan restricciones, aprobaciones y nivel de verificación requerido antes del acceso.

4.1.3. Autorización, revisión y revocación de accesos.

Las solicitudes se autorizan formalmente, los permisos se revisan y los derechos se retiran cuando cesa la necesidad o cambia la relación.

4.1.4. Integración del acceso físico y lógico.

La autorización lógica se complementa con controles de ingreso a recintos, instalaciones y equipos: ambos planos deben tener criterios coherentes.

4.2. Controles de acceso lógico

El control de acceso lógico comprende medidas implementadas por la organización y por sus sistemas para que únicamente usuarios y procesos autorizados accedan a los recursos necesarios. Primero se identifican activos a proteger: sistemas operativos, aplicaciones, código, archivos, bases de datos, redes, utilidades, credenciales y registros. La identificación proporciona una identidad individual —por ejemplo, un nombre de usuario—; la autenticación verifica que esa identidad es legítima mediante algo que se sabe, se posee o se es.

Tras autenticar, la autorización define acciones permitidas, como leer, modificar, ejecutar o administrar. Las listas de control de acceso (ACL) asocian recursos con sujetos y permisos; los roles ayudan a administrar atribuciones según funciones. Las cuentas y credenciales deben gestionarse durante su ciclo de vida, sin cuentas genéricas injustificadas ni contraseñas iniciales permanentes. El principio de mínimo privilegio exige conceder solo los derechos necesarios y retirarlos cuando dejan de serlo. El seguimiento mediante logs y revisión periódica permite detectar permisos excesivos, intentos fallidos y actividades inusuales.

4.2.1. Recursos y activos sujetos a control de acceso.

Deben identificarse aplicaciones, sistemas, archivos, redes, contraseñas, herramientas, código y registros; sin conocer activos no es posible definir permisos adecuados.

4.2.2. Identificación de usuarios y procesos.

La identificación asigna una referencia distinguible a cada usuario o proceso, favoreciendo la trazabilidad y evitando atribuciones ambiguas de acciones.

4.2.3. Autenticación: conocimiento, posesión y características físicas.

La autenticación puede utilizar conocimiento (contraseña), posesión (token, tarjeta) o característica inherente (biometría); la combinación de factores distintos puede aumentar la resistencia a suplantación.

4.2.4. Autorización y asignación de permisos.

La autorización determina qué operaciones puede efectuar una identidad autenticada. Debe basarse en rol, necesidad de conocimiento y sensibilidad del recurso.

4.2.5. Listas de control de acceso (ACL).

Una ACL asocia al recurso los usuarios o grupos autorizados y operaciones permitidas, como lectura, escritura o ejecución; debe mantenerse al día.

4.2.6. Gestión de cuentas y contraseñas.

La gestión de cuentas cubre creación, cambios, bloqueo y baja. Las contraseñas y demás secretos deben protegerse y reemplazarse si se sospecha compromiso.

4.2.7. Gestión de privilegios y principio de mínimo privilegio.

Las cuentas administrativas tienen capacidad de daño elevada; sus privilegios deben ser limitados, autorizados, revisados y utilizados sólo para actividades que los requieren.

4.2.8. Revisión periódica de derechos de acceso.

Las revisiones detectan permisos heredados de funciones anteriores, cuentas inactivas y excepciones innecesarias. Deben ser periódicas y ligadas a cambios de función.

4.2.9. Supervisión y registro de accesos.

El registro y examen de accesos permite investigar intentos fallidos, accesos fuera de lo habitual, uso de privilegios y posibles violaciones de política.

4.3. Controles de acceso físico

El acceso físico establece quién puede entrar y permanecer en instalaciones, áreas seguras y espacios que albergan información o equipos. Los perímetros definen límites con distintas exigencias de protección y los controles administrativos determinan responsables, autorizaciones, horarios y reglas para visitantes. La protección puede combinar cerraduras, credenciales, tarjetas, barreras, cámaras, alarmas y personal de vigilancia, según el riesgo y la criticidad del área.

La identificación y el registro de visitantes, la supervisión durante su permanencia y la devolución de credenciales temporales ayudan a asegurar trazabilidad. Debe evitarse que una autorización de entrada general habilite automáticamente el acceso a salas de servidores o documentación sensible.

4.3.1. Áreas protegidas y perímetros de seguridad.

Los perímetros definen áreas con diferentes necesidades de protección, como espacios públicos, oficinas y salas técnicas especialmente restringidas.

4.3.2. Controles administrativos de acceso físico.

Los controles administrativos fijan responsables de autorización, listas de acceso, reglas de visita, identificación y revisión de permisos.

4.3.3. Controles explícitos: cerraduras, cámaras, alarmas y vigilancia.

Cerraduras, credenciales, sistemas de vigilancia, cámaras y alarmas son controles complementarios; su selección debe justificarse por el riesgo.

4.3.4. Identificación y registro de personal y visitantes.

El registro de entradas, salidas y visitas ayuda a mantener evidencia y permite investigar incidentes físicos. Los visitantes pueden requerir acompañamiento.

4.4. Controles ambientales

Los controles ambientales buscan que la infraestructura y la información no sufran daños por incendio, agua, temperaturas extremas, humedad, fallas de energía, fenómenos naturales o condiciones físicas desfavorables. La selección de medidas exige identificar amenazas propias del edificio y del entorno y determinar qué servicios resultan críticos.

La protección puede incluir detección y extinción de incendios adecuadas, sensores ambientales, climatización, electricidad estabilizada, suministro alternativo, inspección y mantenimiento de instalaciones, y procedimientos de emergencia. La ubicación de equipos, los cableados y la protección de suministros son parte del diseño integral, no solamente asuntos de mantenimiento edilicio.

4.4.1. Riesgos ambientales y amenazas físicas.

Se identifican amenazas de incendio, inundación, electricidad, clima, humedad y otros factores físicos que podrían dañar equipos o impedir el servicio.

4.4.2. Protección de instalaciones, equipos y suministros.

Se protege la ubicación, ventilación, cableado, energía y otros suministros con prevención, detección, mantenimiento y respuesta a emergencias.

4.5. Seguridad de recursos humanos

Las personas constituyen un componente esencial de la seguridad: sus accesos y conocimientos pueden prevenir errores o facilitar incidentes. Antes de la contratación se establecen requisitos del puesto, controles de selección proporcionados y obligaciones de confidencialidad. Durante la relación deben existir responsabilidades claramente comunicadas, formación continua y procedimientos formales para responder a incumplimientos.

Ante la finalización o modificación de la relación laboral, la organización debe revisar autorizaciones, retirar o ajustar accesos, recuperar activos y recordar obligaciones que permanecen vigentes. El

factor humano se trata como una responsabilidad distribuida entre dirección, recursos humanos, líderes, seguridad y usuarios.

4.5.1. Selección y condiciones de contratación.

La selección y contratación deben establecer perfiles, comprobaciones pertinentes y condiciones que informen al trabajador de sus responsabilidades.

4.5.2. Capacitación, concientización y responsabilidades.

La concientización y formación deben repetirse y adaptarse a tareas; conocer la política es indispensable para ejecutarla correctamente.

4.5.3. Medidas disciplinarias.

La organización define procesos conocidos para tratar incumplimientos de seguridad en forma justa, documentada y conforme a los requisitos legales.

4.5.4. Finalización o modificación de la relación laboral.

Ante una baja o cambio de puesto deben recuperarse activos y modificarse o revocarse identidades, credenciales y permisos oportunamente.

4.6. Complemento obligatorio: controles organizativos de acceso ISO 27002:2022, 5.15 a 5.18

Los controles organizativos 5.15 a 5.18 de ISO/IEC 27002:2022 cubren aspectos relacionados pero diferentes: la política y reglas de control de acceso, la administración completa de identidades, la seguridad de la información utilizada para autenticarse y la provisión, revisión, modificación y retiro de derechos. Deben aplicarse de manera articulada: una política adecuada no basta si se crean identidades sin controles, se exponen secretos o se mantienen privilegios después de que cambió la necesidad de acceso.

4.6.1. 5.15 Control de acceso.

El control 5.15 define y aplica reglas de acceso físico y lógico basadas en requisitos de negocio y seguridad de la información. La autorización se fundamenta en la necesidad de acceso, el principio de mínimo privilegio y la adecuación de derechos al riesgo.

4.6.2. 5.16 Gestión de identidad.

El control 5.16 requiere administrar las identidades a lo largo de su ciclo de vida y vincular cada identidad a una entidad reconocible. Incluye altas, cambios, bajas y tratamiento adecuado de identidades compartidas o técnicas cuando sean necesarias.

4.6.3. 5.17 Información de autenticación.

El control 5.17 protege la información de autenticación durante su asignación, uso y administración. Incluye tratamiento seguro de contraseñas, secretos, tokens y medios equivalentes; los usuarios deben conocer sus obligaciones de confidencialidad y cuidado.

4.6.4. 5.18 Derechos de acceso.

El control 5.18 administra los derechos de acceso: asignación, revisión, modificación y retiro, en coherencia con la política y con cambios de rol o relación laboral. Exige procesos autorizados y evita que se acumulen permisos innecesarios.

5. CAPÍTULO 8 — SEGURIDAD ORGANIZACIONAL

5.1. Infraestructura organizacional de seguridad de la información

La seguridad de la información requiere una infraestructura organizacional: estructura de dirección, asignación formal de funciones, mecanismos de coordinación y canales para comunicar políticas y decisiones. Su objetivo es que proteger información no dependa de iniciativas individuales aisladas. La dirección da respaldo, establece prioridades y recursos y determina quién tiene autoridad para aprobar políticas, riesgos, medidas y excepciones.

El responsable o gestor de seguridad articula normas, asesoramiento, seguimiento y propuestas de mejora, sin sustituir a los propietarios de los activos ni a los directores de cada proceso. La coordinación puede realizarse mediante un comité multidisciplinario que reúna áreas operativas, informáticas, legales, recursos humanos y administración; esto facilita gestionar riesgos que afectan transversalmente a la institución. Las políticas y procedimientos deben difundirse a quienes tienen que aplicarlos y revisarse cuando cambien los objetivos o las amenazas.

5.1.1. Importancia de la infraestructura organizacional.

La seguridad necesita estructura estable para coordinar políticas, riesgos, personas, presupuesto y controles; los esfuerzos aislados dejan áreas sin cobertura.

5.1.2. Estructura de gestión y dirección de la seguridad.

La dirección establece prioridades, autoridades, recursos y mecanismos de revisión. Debe respaldar las reglas y controlar su incorporación en los procesos.

5.1.3. Asignación y delegación de responsabilidades.

Cada responsabilidad tiene que quedar asignada y comunicada, evitando vacíos o superposición confusa entre gestores, propietarios y operadores.

5.1.4. Gestor o responsable de seguridad de la información.

El gestor de seguridad propone lineamientos, coordina actividades, asesora y monitorea riesgos; no reemplaza la responsabilidad de cada dueño de activo.

5.1.5. Coordinación de la seguridad y comité multidisciplinario.

La coordinación interdisciplinaria permite integrar seguridad con necesidades legales, humanas, tecnológicas y operativas; un comité puede facilitar decisiones transversales.

5.1.6. Difusión de políticas y procedimientos de seguridad.

Los documentos de política deben ser conocidos por destinatarios y revisarse cuando cambian procedimientos, responsabilidades o riesgos.

5.2. Tratamiento de activos

Un activo es cualquier elemento de valor para la organización. En el contexto de seguridad, los activos primarios comprenden la información, los procesos y las actividades de negocio; los de apoyo incluyen equipos, software, redes, personas, instalaciones, servicios y estructura organizativa. La protección debe responder tanto a su valor como a la repercusión que tendría perder confidencialidad, integridad o disponibilidad.

El inventario permite reconocer qué existe, dónde está, quién es responsable, cómo se utiliza y qué nivel de protección requiere. Un registro útil describe el activo, su ubicación, clasificación, propietario o responsable, dependencias y medidas relevantes. Asignar un propietario no significa necesariamente que sea el usuario exclusivo o el administrador técnico: es quien debe asegurar que se definan usos permitidos, protección y revisión acorde con los requisitos del negocio.

5.2.1. Concepto y protección de activos.

La protección de activos parte de identificar su valor para procesos e información y los daños que produciría su pérdida, exposición o alteración.

5.2.2. Tipos de activos de información y de soporte.

Son activos primarios la información y las actividades; los de apoyo comprenden equipos, programas, redes, servicios, personal, edificios y estructura organizativa.

5.2.3. Inventario de activos.

El inventario identifica activo, ubicación, responsable, clasificación, uso, dependencias y medidas de protección, y debe mantenerse actualizado.

5.2.4. Propiedad y responsabilidades sobre los activos.

El propietario del activo determina y revisa requisitos de protección, uso aceptable y restricciones, aunque delegue su custodia o administración cotidiana.

5.3. Seguridad en las relaciones con terceros

Las relaciones con contratistas, proveedores y terceros pueden introducir riesgos porque personas o servicios externos necesitan acceder a instalaciones, sistemas o información de la organización. Antes de permitir el acceso deben identificarse los terceros, los activos involucrados, la finalidad, el alcance, la duración y las amenazas derivadas de la relación. El análisis determina restricciones y requisitos de seguridad apropiados.

Los acuerdos deben definir responsabilidades, confidencialidad, mecanismos de autenticación, tratamiento de incidentes, devoluciones o eliminación de información, continuidad, auditoría y cumplimiento legal y contractual cuando resulte pertinente. La organización no deja de ser responsable de sus riesgos por externalizar un servicio: necesita supervisar el desempeño, verificar compromisos, gestionar cambios y revocar autorizaciones cuando la relación termina.

5.3.1. Terceros, contratistas y proveedores.

Terceros incluyen proveedores, contratistas, prestadores de servicios, visitantes con acceso y otras entidades externas que interactúan con recursos de la organización.

5.3.2. Riesgos asociados al acceso de terceros.

El acceso de terceros introduce riesgos de divulgación, cambios indebidos y dependencia operativa; se evalúa antes de otorgar permisos.

5.3.3. Requisitos y acuerdos de seguridad con terceros.

Los requisitos de seguridad se integran a políticas y acuerdos que definan alcance, autorizaciones, protección de información y respuesta ante incidentes.

5.3.4. Responsabilidades y obligaciones contractuales.

Las obligaciones contractuales pueden incluir confidencialidad, cumplimiento, niveles de servicio, auditoría, devolución de información y condiciones de finalización.

5.3.5. Gestión y seguimiento de servicios de terceros.

La organización debe revisar desempeño, cambios, incidentes y cumplimiento del proveedor durante toda la relación, no sólo al firmar el contrato.

5.4. Complemento obligatorio: controles de personas ISO 27002:2022, 6.1 a 6.8

Los controles de personas 6.1 a 6.8 de ISO/IEC 27002:2022 cubren el ciclo completo de la relación con quienes trabajan para la organización y determinadas condiciones especiales de prestación. No se reducen a recursos humanos: vinculan comprobación y contratación con formación, disciplina, confidencialidad, cambio de funciones, teletrabajo y comunicación temprana de eventos sospechosos. Su objetivo conjunto es que las personas comprendan sus responsabilidades y puedan desempeñarlas con seguridad.

5.4.1. 6.1 Comprobación.

La comprobación previa de antecedentes o condiciones relevantes debe ser apropiada al cargo, al acceso previsto y al riesgo, respetando legislación y protección de datos. Se procura verificar idoneidad y confiabilidad sin exceder lo necesario.

5.4.2. 6.2 Términos y condiciones de contratación.

Los términos y condiciones de contratación deben comunicar responsabilidades de seguridad de la organización y de la persona, incluyendo políticas aplicables y deberes sobre uso de activos, información y confidencialidad.

5.4.3. 6.3 Concienciación, educación y formación en seguridad de la información.

La concienciación, educación y formación deben adaptarse a funciones y riesgos y mantenerse durante la relación laboral. Los usuarios necesitan comprender amenazas habituales, obligaciones, conductas esperadas y cómo reportar situaciones sospechosas.

5.4.4. 6.4 Proceso disciplinario.

El proceso disciplinario debe estar formalizado y ser conocido para tratar incumplimientos de políticas de seguridad. Debe aplicarse con proporcionalidad y conforme a las disposiciones laborales y legales pertinentes.

5.4.5. 6.5 Responsabilidades ante la finalización o cambio.

Al concluir o cambiar una relación laboral deben definirse y ejecutarse responsabilidades subsistentes, devolución de activos y ajuste o retiro de accesos. También deben comunicarse los cambios a las áreas que administran sistemas y servicios.

5.4.6. 6.6 Acuerdos de confidencialidad o no divulgación.

Los acuerdos de confidencialidad o no divulgación deben adecuarse a la información protegida, a las partes firmantes y a sus obligaciones. Deben revisarse cuando cambien las necesidades y contemplar deberes que puedan continuar tras finalizar la relación.

5.4.7. 6.7 Teletrabajo.

El teletrabajo precisa medidas acordes al tratamiento de información fuera del entorno habitual: protección de dispositivos y redes, condiciones físicas, privacidad, acceso remoto, soporte e incidentes. Los riesgos dependen de las tareas y del contexto de trabajo.

5.4.8. 6.8 Notificación de eventos de seguridad de la información.

El personal debe contar con medios sencillos y conocidos para notificar prontamente eventos de seguridad observados o sospechados. La organización define destinatarios, procedimiento, datos necesarios y acciones iniciales apropiadas.

6. CAPÍTULO 9 — GESTIÓN DE LA CONTINUIDAD DEL NEGOCIO

6.1. Fundamentos de continuidad del negocio

La continuidad del negocio es la capacidad de mantener o restablecer productos, servicios y procesos esenciales ante interrupciones que dificulten la actividad normal. No se limita a recuperar servidores: considera personas, instalaciones, comunicaciones, proveedores, datos y decisiones necesarias para sostener operaciones. La dirección debe determinar qué procesos son críticos, qué dependencias los sostienen y qué niveles de interrupción son aceptables.

Un plan de continuidad del negocio articula la respuesta organizacional general; los planes de contingencia especifican alternativas y acciones frente a escenarios adversos; la recuperación ante desastres se concentra especialmente en restablecer recursos y capacidades afectadas. Son conceptos relacionados pero no sinónimos: restaurar una base de datos es una parte posible de recuperar un servicio al cliente, no el servicio completo.

6.1.1. Concepto y objetivos de continuidad del negocio.

El propósito es sostener procesos y servicios críticos ante fallas, minimizando consecuencias y fijando prioridades y niveles aceptables de recuperación.

6.1.2. Procesos críticos y dependencias tecnológicas.

Se identifican actividades indispensables y su dependencia de personas, sistemas, datos, instalaciones, comunicaciones y proveedores.

6.1.3. Continuidad, contingencia y recuperación ante desastres.

Continuidad abarca actividades esenciales del negocio; contingencia reúne respuestas alternativas; recuperación ante desastres se enfoca en restablecer capacidades dañadas.

6.1.4. Responsabilidades de la dirección.

La dirección fija objetivos, recursos, responsables, aprobación, pruebas y revisión de planes, porque la continuidad es una decisión de negocio.

6.2. Gestión de la continuidad del negocio

La gestión de continuidad combina medidas preventivas para disminuir la probabilidad y gravedad de interrupciones con estrategias de respuesta y recuperación cuando éstas ocurren. Debe prever la seguridad de la información durante escenarios degradados: cambios urgentes, trabajo desde lugares alternativos, acceso de emergencia, soportes provisionales y restablecimiento de datos no pueden quedar fuera de los requisitos de confidencialidad, integridad y trazabilidad.

La seguridad se integra al programa general de continuidad mediante análisis de riesgos, selección de procesos críticos, prioridades, planes documentados, responsables, pruebas y revisión. Es necesario evitar soluciones de contingencia que permitan reanudar rápidamente un servicio a costa de perder de forma incontrolada la información que ese servicio procesa.

6.2.1. Prevención y recuperación.

Se combinan controles para prevenir interrupciones con estrategias para responder, operar provisionalmente y recuperar procesos y recursos.

6.2.2. Seguridad de la información durante las interrupciones.

Durante emergencias deben conservarse protecciones de información o compensaciones justificadas, aunque se utilicen entornos y procedimientos alternativos.

6.2.3. Integración de la seguridad con la gestión de continuidad.

La seguridad se integra en la continuidad desde la evaluación de riesgos hasta las pruebas, evitando estrategias de recuperación que expongan datos.

6.3. Análisis de riesgos y continuidad del negocio

El análisis de riesgos identifica amenazas capaces de detener procesos o servicios, las vulnerabilidades que pueden facilitar la interrupción y las consecuencias sobre la organización. Se consideran fallas de suministro, incidentes de seguridad, eventos naturales, indisponibilidad de personal, problemas con terceros, fallas de infraestructura y errores operativos. La evaluación combina probabilidad e impacto con el fin de priorizar situaciones que requieren preparación y tratamiento.

La criticidad no depende solamente del precio del equipo: incluye pérdida económica, incumplimiento de obligaciones, afectación reputacional, interrupción de atención y pérdida de datos esenciales. Este análisis alimenta el plan de continuidad y orienta inversiones de mitigación, redundancia y recuperación.

6.3.1. Amenazas, vulnerabilidades e interrupciones.

Una amenaza puede provocar interrupciones cuando encuentra vulnerabilidades físicas, técnicas, humanas u organizacionales; se estudian escenarios verosímiles.

6.3.2. Probabilidad, impacto y criticidad.

La probabilidad y las consecuencias determinan exposición al riesgo; la criticidad de un proceso incluye el impacto de su detención sobre el negocio.

6.4. Plan de continuidad del negocio

El plan de continuidad documenta cómo se responderá a una interrupción y de qué manera se preservarán o recuperarán actividades prioritarias. Debe establecer alcance, objetivos, hipótesis, escenarios, responsables, contactos, activación, comunicación, procedimientos de contingencia, prioridades, recursos, criterios de retorno a la normalidad y mecanismos de mantenimiento. Las estrategias se seleccionan según riesgos, costos, dependencias y tiempos de recuperación aceptables.

El desarrollo exige coordinación entre áreas y aprobación de la dirección. Las pruebas pueden consistir en revisión de escritorio, ejercicios por escenarios, simulaciones, pruebas parciales de recuperación y ensayos integrales proporcionados al riesgo. Luego de cada ejercicio se registran resultados, dificultades y acciones de mejora; los planes deben reevaluarse ante cambios de sistemas, proveedores, procesos o instalaciones.

6.4.1. Estructura del plan.

El plan debe contener alcance, escenarios, prioridades, roles, contactos, activación, comunicaciones, estrategias, procedimientos y retorno a operaciones normales.

6.4.2. Desarrollo e implementación.

El desarrollo involucra a responsables de procesos y tecnología; las estrategias y procedimientos se documentan, aprueban y comunican a los equipos pertinentes.

6.4.3. Estrategias de recuperación y respuesta.

Las respuestas comprenden contención, decisiones de emergencia, alternativas de operación, respaldos, recursos sustitutos y recuperación progresiva según prioridades.

6.4.4. Pruebas del plan.

Las pruebas verifican que procedimientos, personas y recursos funcionan bajo escenarios acordados. Pueden ser de escritorio, simulaciones o ejercicios prácticos.

6.4.5. Mantenimiento y reevaluación.

Después de ensayos e incidentes se analizan fallas y actualizan planes, contactos y dependencias para mantener su utilidad.

6.5. Gestión de incidentes y eventos adversos

Un evento de seguridad es una ocurrencia que puede indicar un fallo de control o una posible vulneración; un incidente supone una o varias ocurrencias que pueden comprometer activos o la operación y requieren gestión. Deben existir canales y responsables para notificar señales de anomalía, documentar hechos y valorar su gravedad. La información recibida debe permitir decidir si es necesario activar procedimientos de respuesta, escalar a dirección o activar contingencia.

La gestión de incidentes comprende recepción, evaluación, asignación de responsables, contención, análisis, recuperación, comunicación y aprendizaje. Los roles deben estar acordados antes de que ocurra el problema; durante una crisis, la improvisación de responsables y contactos aumenta el impacto. La respuesta debe preservar evidencias cuando corresponda y registrar decisiones y acciones.

6.5.1. Notificación de eventos adversos.

El personal debe informar oportunamente cualquier evento sospechoso por canales conocidos, aportando datos observados sin alterar evidencia.

6.5.2. Procedimientos de gestión de incidentes de seguridad.

El proceso formal cubre detección, registro, evaluación, clasificación, respuesta, recuperación y aprendizaje de incidentes.

6.5.3. Responsables de respuesta y escalamiento.

Se asignan destinatarios de avisos, equipos de respuesta, facultades de decisión y reglas de escalamiento según gravedad e impacto.

6.6. Planes de contingencia

Los planes de contingencia preparan actuaciones específicas frente a situaciones de desastre o pérdida de recursos críticos. Su elaboración comienza con la definición de objetivos, alcance y responsables; luego identifica escenarios de interrupción, recursos, sistemas, funciones y servicios esenciales. El análisis de impacto en el negocio (BIA) valora cómo evoluciona el daño con el tiempo, identifica dependencias y ayuda a fijar prioridades y tolerancias.

El RTO (Recovery Time Objective) expresa el tiempo objetivo máximo previsto para restablecer una actividad o recurso tras una interrupción; el RPO (Recovery Point Objective) expresa el punto de recuperación de datos y, por tanto, la pérdida temporal de información que se considera tolerable. No deben confundirse: uno limita duración de indisponibilidad y el otro pérdida de información. Las alternativas pueden incluir medios redundantes, sitios alternativos, respaldos, acuerdos de soporte y procedimientos manuales. Se comparan por costo, viabilidad, tiempo, recursos y riesgos, se seleccionan formalmente y se documentan como procedimientos operativos y responsabilidades de los equipos de respuesta.

El plan debe ensayarse mediante capacitación, simulaciones, pruebas parciales e integrales, y actualizarse según los resultados y los cambios del negocio. La restauración requiere no sólo recuperar datos o infraestructura, sino verificar integridad, autorizaciones y funcionamiento antes de declarar restablecido el servicio.

6.6.1. Objetivos y alcance.

El alcance determina qué procesos y escenarios cubrirá el plan, las hipótesis asumidas, los responsables y los objetivos de recuperación.

6.6.2. Identificación de situaciones de desastre.

Se identifican desastres posibles, tales como incendio, fallas prolongadas, pérdida de conectividad, ataques o indisponibilidad de una instalación.

6.6.3. Identificación de recursos, funciones y procesos críticos.

Se catalogan procesos, aplicaciones, bases de datos, equipos, instalaciones, personal y proveedores necesarios para operar y recuperarse.

6.6.4. Análisis de impacto en el negocio (BIA).

El BIA analiza consecuencias de la interrupción a medida que pasa el tiempo, identifica dependencias y ayuda a priorizar actividades y determinar tolerancias.

6.6.5. Definición del tiempo de recuperación (RTO).

El RTO define el objetivo temporal de restauración de actividad o servicio. Debe ser compatible con la tolerancia del negocio y la capacidad real de recuperación.

6.6.6. Definición del punto de recuperación (RPO).

El RPO representa hasta qué punto anterior en el tiempo es aceptable recuperar la información. Se utiliza para decidir periodicidad y modalidad de respaldos y replicación.

6.6.7. Análisis de alternativas de recuperación.

Se comparan alternativas como redundancia, sitios alternativos, restauración de respaldos, soporte de terceros y operación manual temporal.

6.6.8. Informe y selección de alternativas de recuperación.

La selección debe justificar costos, plazos, recursos, riesgos, limitaciones y beneficios; el informe permite aprobar una estrategia coherente con prioridades.

6.6.9. Desarrollo del plan de contingencia y equipos de respuesta.

El plan detalla activación, contactos, funciones de equipos, coordinación, comunicación y asignación de tareas durante el desastre.

6.6.10. Procedimientos de restauración de servicios e información.

Los procedimientos deben precisar qué restaurar primero, origen de respaldos, dependencias, verificaciones de integridad, autorizaciones y criterios de vuelta al servicio.

6.6.11. Entrenamiento, simulacros y pruebas integrales/parciales.

El entrenamiento procura que los responsables conozcan sus actuaciones; las pruebas parciales verifican componentes y las integrales ponen a prueba la coordinación global.

6.6.12. Evaluación, actualización y mejora del plan.

La evaluación recoge resultados de incidentes y simulacros, corrige debilidades y revalida el plan cuando cambian sistemas o procesos.

6.7. Complemento obligatorio: controles ISO 27002:2022, 5.29 a 5.31

Los controles 5.29, 5.30 y 5.31 de ISO/IEC 27002:2022 tienen alcances diferenciados. El 5.29 trata la protección de la información mientras existe una interrupción; el 5.30 exige preparar la tecnología de información y comunicaciones para apoyar los objetivos de continuidad; el 5.31 se refiere a identificar, documentar y mantener actualizados requisitos legales, reglamentarios y contractuales. Este último se incluye en el bloque por exigencia del temario, pero no constituye un procedimiento técnico de recuperación.

6.7.1. 5.29 Seguridad de la información durante la interrupción.

El control 5.29 propone planificar cómo se mantendrá un nivel apropiado de seguridad de la información durante una interrupción. Las alternativas de continuidad deben preservar controles esenciales o establecer compensaciones explícitas.

6.7.2. 5.30 Preparación de las TIC para la continuidad del negocio.

El control 5.30 pide planificar, implementar, mantener y probar la preparación de las TIC para apoyar la continuidad del negocio. Se vincula con requisitos de recuperación, capacidad alternativa, dependencias tecnológicas y verificación de soluciones.

6.7.3. 5.31 Identificación de requisitos legales, reglamentarios y contractuales.

El control 5.31 establece identificar, documentar y actualizar obligaciones legales, reglamentarias y contractuales relacionadas con seguridad de la información, y determinar cómo cumplirlas. Aunque está situado aquí por el programa, su naturaleza es de cumplimiento.